Security incident report

Section 1: Identify the network protocol involved in the incident
The network protocols identified in the tcpdump traffic log are DNS, TCP, HTTP, and IP. ● DNS (Domain Name System): Translates domain names, such as yummyrecipesforme.com and greatrecipesforme.com, into IP addresses. ● TCP (Transmission Control Protocol): Establishes a reliable connection between the user's computer and the web server. The three-way handshake is visible in the log through the flags [S], [S.], and [.]. ● HTTP (Hypertext Transfer Protocol)**:** Allows the browser to request web pages from the server. The log shows HTTP GET requests and traffic over port 80. ● IP (Internet Protocol): Provides addressing so that packets can travel between the user's computer and the servers.

Section 2: Document the incident
The incident occurred on the yummyrecipesforme.com website. Several customers contacted the support team, reporting that the website prompted them to download and execute a file to access free recipes. After running the file, their browsers were redirected to greatrecipesforme.com, and their computers began running more slowly. During the investigation, the cybersecurity analyst used a sandbox environment and tcpdump to examine network traffic. The logs showed that the browser first queried the DNS server to obtain the IP address of yummyrecipesforme.com and then established an HTTP connection to the web server. After the downloaded file was executed, the browser queried DNS for greatrecipesforme.com and established an HTTP connection to that website. An inspection of the website's source code revealed that malicious JavaScript had been added to prompt visitors to download an executable file. Analysis of the downloaded file confirmed that it redirected visitors' browsers to the fake website containing malware. The investigation determined that a former employee had used a brute-force attack to access the administrative panel by repeatedly trying known default passwords. The attack succeeded because the administrator account still used its default password and there were no controls to limit login attempts. The attacker then modified the website's

source code and changed the administrator password, preventing the website owner from accessing the administrative account.

The evidence included customer complaints, tcpdump network traffic logs, the website's source code, and the analysis of the downloaded file.

Section 3: Recommend one remediation for brute force attacks
I recommend limiting the number of failed login attempts on the administrative panel. After several unsuccessful attempts, the system should temporarily block further attempts and generate a security alert. This measure helps prevent brute-force attacks by limiting how many passwords an attacker can try. The organization should also replace default passwords with strong, unique passwords.